

Stoquify blocker and gate control plane — current-state assessment

G1 technical remediation, authentic approval requirements, and controlled next steps

BLOCKER AND GATE CONTROL REPORT

Prepared 2026-08-18

Evidence-bound | approval-gated | fail-closed

No production claim without authentic evidence.

Prepared: 2026-08-18 Assessment class: repository evidence review and non-destructive baseline validation Release claim: none

Executive finding

Stoquify does **not** need a greenfield gate platform. A substantial Workflow Assurance foundation already exists and should be extended.

The repository already supports versioned assurance checks, organization-scoped runs, findings, incidents, source hashes, alerts, waivers, a control-tower UI, tenant-aware actions, fresh authentication, business events, outbox delivery, domain sign-offs, maker-checker checks, evidence grading and redaction.

The missing platform capability is narrower but material: Stoquify does not yet have a generalized authoritative role registry, decision/approval-policy catalog, authenticated approval aggregate, immutable evidence envelope or independent approval-verification record. G1 currently stores its policy and approvals in repository JSON rather than a tenant-scoped production workflow.

Recommendation: extend `services/assurance/` and its existing persistence/UI. Do not create a second control plane and do not replace domain-owned workflow truth.

Verified baseline

G1 frozen contract SHA-256	PASS	Independently recomputed as 11434eb3e1af1826516426e90d2d53a2faa47ade361d91191b5f3e0c950a36db.
G1 approval-register SHA-256	OBSERVED	49e19d9ed6c83df23010264ffff4bb92dbe63ba4c2e7a8e3acdc42c0e4fe8340; this digest describes the current open register, not an approval.
npm run pos:g1:contract:gate	EXPECTED BLOCKED	13/13 technical checks pass; authenticated approvals are 0/11. Exit code 1 is correct fail-closed behavior.
npm run pos:enterprise:program:gate	EXPECTED BLOCKED	Program controller ready; first blocker G1; 0/10 gates and 0/9 external-evidence items verified.
Focused G1/program tests	PASS	2 suites, 4 tests passed.
npm run prisma:validate	PASS	Current prisma/schema.prisma is valid.
npm run typecheck	PASS	TypeScript completed with exit code 0.
npm run policy:gates	SKIPPED	Candidate is ineligible while G1 authenticated approvals remain 0/11.
npm run verify:release	SKIPPED	Release-wide verification must not imply eligibility before G1 closure.

The older generated `EXECUTION_06_G1_CONTRACT_GATE_REASSESSMENT.json` records the pre-fix 12/13 state. The live non-writing gate and the post-fix report are the current evidence: cash-only control now passes. Historical evidence should remain unchanged and be marked superseded rather than overwritten.

Repository evidence inspected

Primary evidence:

- 1 docs/pos-enterprise-grade-audit/EXECUTION_06_G1_CONTRACT_FREEZE_V0_2_0.json
- 1 docs/pos-enterprise-grade-audit/EXECUTION_06_G1_CONTRACT_APPROVAL_REGISTER.json

```
1 docs/pos-enterprise-grade-audit/EXECUTION_07_G2_G9_GATE_CLOSURE_PROGRAM.json
1 docs/blockers-and-gates/G1_SIGNATURE_VALIDATION_AND_GATE_CLOSURE_GUIDE_2026-08-18.md
1 what-next/AQSTOQFLOW_G1_GATE_CLOSURE_EXECUTION_REPORT_2026-08-18.md
1 scripts/pos-g1-contract-gate.js
1 scripts/pos-enterprise-program-gate.js
1 scripts/__tests__/pos-g1-contract-gate.test.js
1 scripts/__tests__/pos-enterprise-program-gate.test.js
```

Architecture and platform evidence:

```
1 graphify-out/GRAPH_REPORT.md
1 graphify-out/GRAPH_REPORT_actions.md
1 graphify-out/graph_actions.json
1 prisma/schema.prisma
1 lib/security/auth-session.ts
1 lib/security/audit-log.ts
1 services/_shared/protect.ts
1 services/events/business-event.service.ts
1 services/evidence/evidence-contracts.ts
1 services/evidence/evidence-grade.service.ts
1 services/evidence/evidence-blockers.service.ts
1 services/assurance/assurance-registry-contracts.ts
1 services/assurance/assurance-registry.service.ts
1 services/assurance/assurance-registry-persistence.service.ts
1 services/assurance/assurance-incident.service.ts
1 services/assurance/assurance-control-tower.service.ts
1 services/assurance/assurance-alert-delivery.service.ts
1 actions/assurance/workflow-assurance-incident.actions.ts
1 app/[locale]/(dashboard)/dashboard/assurance/control-tower/
1 services/end-of-day-close/branch-daily-close-sign-off.service.ts
1 actions/end-of-day-close/branch-daily-close-sign-off.actions.ts
1 services/hris/approval-inbox.service.ts
1 actions/hris/approval-inbox.actions.ts
```

The graph reports confirm that authentication/RBAC, ledger-first operational posting, Workflow Assurance, evidence and POS are established architectural communities. The approval and fresh-authentication action paths appear as smaller domain-specific communities, supporting the finding that the primitives exist but are fragmented.

Current inventory

Implemented and reusable

Tenant identity and application roles	User, Role, Organization; requireRbacContext()	Reuse for account identity and access. Do not treat Role as governance authority.
Fresh authentication	Session.assurance*; requireFreshAuth(300)	Reuse. Capture a frozen attestation snapshot in each approval.
Protected server actions	protect() with permission, tenant guard, module gate and fresh auth	Reuse as the only public mutation boundary.
Versioned assurance definitions	WorkflowAssuranceCheckDefinition	Extend with approval/gate policy references; preserve domain checks.
Organization-scoped executions	WorkflowAssuranceCheckRun and findings	Reuse for technical/evidence checks and verifier runs.
Blocker lifecycle	WorkflowAssuranceIncident and events	Reuse as the canonical operational blocker/case model.
Waiver maker-checker	WorkflowAssuranceWaiver; requester cannot approve own waiver	Reuse and strengthen with policy-specific required roles and source hashes.
Notifications	WorkflowAssuranceAlertDelivery, in-app/webhook, dedupe/recovery	Reuse. Notification must never equal approval.
Control-tower UI	Assurance control-tower routes and components	Extend with approval, authority, artifact and verification views.
Stable JSON hashing	Assurance and Business Event canonicalization helpers	Consolidate behind one versioned canonicalization contract.
Business events/outbox	BusinessEvent, BusinessEventOutbox, idempotency and payload hash	Reuse for approval and invalidation events.
Domain sign-off	BranchDailyCloseSignOff	Use as strongest internal reference: source-hash binding, fresh auth, idempotency, serializable transaction, audit and event.
Domain maker-checker	Reconciliation, HRIS and assurance-waiver services	Extract common policy evaluation without moving domain truth.
Evidence grading and proof trails	services/evidence/	Extend subject types to approval, artifact, gate and verification.
Compliance evidence	ComplianceEvidence with hash, source and authority reference	Reuse through an adapter; do not turn it into the universal approval table.

Implemented but incomplete for the proposed capability

Role and user-role relationships	Application permissions exist, but appointment provenance, effective scope, qualification and governance authority do not.
AuditLog	Useful operational audit record, but no universal hash chain or database-level append-only enforcement is proven. Sensitive approval writes should be transactional and fail closed.
Workflow Assurance definitions	Model checks and incidents, but do not model multi-role decision obligations, quorum or gate dependencies.
Workflow Assurance waivers	Support request/approval and expiry, but the current model stores one approver and does not snapshot fresh-authentication evidence or a policy version.
Branch daily-close sign-off	Strong pattern but domain-specific and single-sign-off oriented. It does not supply a reusable multi-decision/multi-role policy.
HRIS approval inbox	Strong projection and self-approval controls, but domain-owned, metadata-heavy and not an approval evidence ledger.
Agent activation approvals	Contain decision, approver, evidence hash, expiry and idempotency, but are package-specific and do not capture fresh-authentication or authority evidence.
Evidence services	Cover selected financial proof subjects. Artifact, policy, approval and gate subjects are not yet represented.
G1 scripts	Correct fail-closed repository gates, but approvals are detached JSON and not collected through a tenant-scoped runtime workflow.

Missing

- 1 General `AuthorityAssignment` and `AuthorityDelegation` records separate from application roles.
- 1 Qualification evidence and review status for qualified country/accounting/security reviewers.
- 1 General artifact registry with canonicalization profile, current digest and supersession history.
- 1 Versioned decision policy with required roles, quorum, order and segregation rules.
- 1 General approval request and append-only approval entry.
- 1 Frozen authentication-attestation snapshot linked to an approval.
- 1 General evidence envelope with deterministic digest and export version.
- 1 Independent verification record and verifier identity/separation policy.
- 1 Persistent gate definition/dependency/run aggregate connecting assurance checks and approval policies.
- 1 Explicit invalidation graph from changed artifact/policy/authority to approvals and downstream gates.
- 1 Provider-neutral external-signature envelope adapter.
- 1 Unified hash format and canonicalization-version registry.

Duplicated or inconsistent

- 1 Canonical JSON and SHA-256 helpers exist in assurance, events, compliance and domain services.
- 1 Approval evidence is represented by several unrelated fields such as `approvalEvidenceHash`, `approvalDigest`, `evidenceHash` and signed source hashes.
- 1 Maker-checker rules are implemented repeatedly in domain services.
- 1 Some hashes are bare 64-character hex strings while others use `sha256:` prefixes and 71-character columns.
- 1 Approval inboxes and review projections are domain-specific with no shared evidence contract.
- 1 Repository gate JSON and production Workflow Assurance are separate evidence planes.

Unsafe or ambiguous if reused without change

- 1 User .name, job title or a mutable role display name cannot be the approval identity key.
- 1 A user-role relationship does not prove formal authority for a governance decision.
- 1 AuditLog alone should not be described as cryptographically tamper-evident.
- 1 A file path without a digest cannot prove which content was approved.
- 1 Client-computed approval hashes, as seen in some UI flows, require server recomputation before trust.
- 1 A generic service must not read every database table directly; domain adapters must expose governed read models.
- 1 The producer of an evidence envelope cannot silently be the independent verifier when policy requires checker separation.

Intentionally manual

- 1 Appointment of accountable governance owners.
- 1 Qualification review for Cameroon, accounting, security or legal reviewers.
- 1 Deliberate decision choice and approval/rejection.
- 1 Risk acceptance, exceptional waiver decisions and legal enforceability conclusions.
- 1 Conflict resolution when authoritative sources disagree.

Automation-boundary matrix

Accountable/legal name	Identity provider or HR identity record keyed by user ID	Yes, through adapter	Required when sources conflict	<code>controls.authority.read</code> ; ordinary auth for read	Stable subject must match active Stoquify user	Identity disabled, source conflict	HR/security identity owner
Internal user ID	Stoquify <code>User.id</code>	Yes	No, unless mapping conflict	Tenant-scoped read	Active user in same organization	User disabled/deleted	Organization admin
Organization ID	Trusted session/RBAC context	Yes	No	Derived server-side	Must equal record tenant	Cross-tenant mismatch	Security/platform owner
Application role	Role relationship	Yes	No	RBAC read	Active tenant role	Role removed	Organization admin
Governance authority	Authority assignment registry plus appointment evidence	Candidate lookup only	Yes for appointment/change	<code>controls.authority.manage</code> ; fresh auth	Effective scope, dates and source digest	Expiry, revocation, scope or evidence change	Governance owner
Delegated authority	Authority delegation registry	Yes after authorized creation	Delegator/governance approval required	Fresh auth; maker-checker where required	Delegator holds delegable authority; bounded dates/scope	Expiry, revocation, delegator authority loss	Governance owner
Qualified reviewer status	Qualification/evidence adapter	Yes for status	Qualified reviewer/governance function must confirm	Restricted evidence access; fresh auth on approval	Qualification type, jurisdiction, expiry, conflict check	Expiry, revocation, conflict	Country/accounting/security reviewer owner
Artifact ID and version	Artifact registry/domain source	Yes	Domain owner freezes version	Artifact manage permission; fresh auth for freeze	Unique version, immutable after freeze	Superseded or content drift	Artifact/domain owner
Artifact path/URI	Registered source connector	Yes	No	Evidence read	Bounded URI scheme and tenant scope	Missing/unreachable source	Source-system owner
Artifact SHA-256	Server hash service	Yes	No	System capability	Versioned canonicalization and independent recomputation	Digest mismatch	Artifact owner/security
Decision ID	Versioned policy catalog	Yes	Policy owner approves definition	Policy manage; fresh auth	Unique within policy version	Policy superseded	Controls/domain owner
Selected option	Frozen decision request	Display and copy automatically	Deliberate human decision	Exact required authority; fresh auth	Must be permitted by policy and displayed payload	Artifact/policy change	Accountable approver
Approval/rejection intent	Explicit server action	No	Always	Required authority; fresh auth	One deliberate action, anti-replay token, exact payload	Session/policy/artifact drift	Accountable approver

Authentication method	Verified session assurance	Yes	No	Step-up path	Accepted method/level and same organization	Revocation or stale session	Security owner
Fresh-authentication time	Session assurance record	Yes	Signer performs step-up	Five-minute recommended window	Must precede approval and be within policy limit	Expired/future/mismatched timestamp	Signer/security
Approval timestamp	Trusted server clock	Yes	No	Approval mutation	Monotonic server time	Clock/control failure	Platform/SRE
Evidence-envelope hash	Server canonicalizer	Yes	No	System capability	Recompute using recorded canonicalization version	Any content change	Evidence service owner
Verification status	Independent verifier run	Yes	Human checker if policy requires	controls.verify; fresh auth for certification	Verify identities, roles, hashes, quorum, SoD and freshness	Source change, expired authority, verifier conflict	Independent checker
Gate status	Gate evaluator	Yes	Only exception/waiver decisions	Gate-run permission; service identity	All dependencies and obligations resolved	Dependency invalidation or new blocker	Gate owner
Waiver/exception	Waiver workflow	Workflow routes request	Request and independent approval required	controls.manage; fresh auth	Reason, evidence, expiry, policy allowability, requester != approver	Expiry, revocation, source change	Risk/control owner

G1 requirement map

Contract identity/version/hash	Frozen G1 JSON and approval register	Independent SHA-256 and exact register binding	POS architecture/control owner	Ready; hash verified.
D-01 through D-11 definitions	Frozen G1 decisions array	Exact IDs, selected options and required roles	Product/control owners	Ready as repository policy; must become versioned runtime policy.
33 role obligations	Three required roles per decision	Deterministic expansion and unique obligation keys	Approval orchestration owner	Can be generated automatically; none satisfied.
Candidate signers	User/role/HR sources	Same tenant and active identity	HR/security	Current document names conflict; do not import as authority.
Confirmed authority	Proposed authority registry	Active, scoped, sourced assignment	Governance owner	Missing; first human-governance prerequisite.
Fresh authentication	Existing session assurance	Five-minute maximum and tenant binding	Security owner	Technical capability exists; not connected to G1 approvals.
Explicit approval	Proposed approval action	Exact decision, option, contract hash and policy version	Each required approver	Missing.
Immutable evidence	Proposed approval entry/envelope and business event	Deterministic digest, append-only history	Evidence owner	Missing as reusable aggregate.
Independent verification	Proposed verifier run	All 33 obligations, SoD, authority and drift	Checker/control owner	Missing.
G1 gate ingestion	Current gate script plus proposed adapter	Read only verified evidence	POS gate owner	Current script reads detached JSON; adapter required.

Reviewer findings

Enterprise/platform architecture	Extend Workflow Assurance as a modular monolith capability first; do not create a parallel service or let it own domain truth.
Backend/domain/integration	Use bounded domain evidence adapters, transactional approval writes, idempotency keys and outbox events.
Data/database/migration	Add new append-oriented tables through additive migrations; reuse existing assurance foreign keys and avoid migrating historical JSON as approved evidence.
Application security/IAM/privacy	Separate RBAC access from governance authority; require fresh auth and server-side checks; minimize and redact personal evidence.
Frontend/design systems	Extend the existing assurance control tower and HRIS-style inbox patterns; UI is a projection, never the security boundary.
Workflow/accessibility/localization	Provide explicit states, bilingual EN/FR content, keyboard/screen-reader support, recovery routes and non-color status cues.
Product/business process	The immediate value is G1 closure tooling; the reusable product is approval and evidence orchestration, not automatic management judgment.
Quality/release assurance	Add contract, state-machine, drift, replay, SoD, tenant, browser and migration tests before enforce mode.
SRE/DevSecOps/observability	Reuse assurance scheduler/alerts; add stuck-approval, verifier-lag, drift and dead-letter metrics plus reconciliation jobs.
SaaS packaging/customer operations	Package as a governed Controls/Assurance capability; decide which base modules include read-only evidence and which plans enable workflow administration.
Finance/internal controls	Multi-role quorum and maker-checker must be policy-driven; domain financial records remain authoritative.
OHADA/country pack	Country/accounting qualifications require dated provenance and qualified human review; no software-generated statutory claim.
Audit/evidence/records governance	Define canonicalization, retention, supersession, redaction and export verification before calling evidence immutable or defensible.
POS/inventory/offline	Use G1 as pilot; preserve POS gate order and cash-only development contract.
Purchasing/AP	Reuse three-way-match and payment-release controls through adapters; do not merge AP data into generic tables.
HRIS/payroll/privacy	Reuse authority/delegation and inbox lessons, but keep employee-sensitive data behind HR permissions and redaction.
Payments/provider/reconciliation	Provider truth and settlement evidence remain external/domain-owned; attach references and digests, not copied secrets.
Accounting close/ledger	Sign-off patterns are reusable; the control plane cannot post ledger entries or certify a close.
Analytics/data governance	Metrics need governed definitions: obligation aging, blocker time, verification lag and invalidation rate; no ranking of individual approvers.
AI/agent safety	Agents may collect, explain and route evidence but cannot make human approvals, accept risk or impersonate a verifier.
API/webhook/events	Use versioned API contracts, business events/outbox, idempotency and provider-neutral signature adapters.
Change management/training/support	Introduce authority-roster ownership, operating procedures, reviewer training and support runbooks before enforcement.

Current decision

The repository is ready for a **design-approved, implementation-not-yet-authorized** G1 pilot built as an extension of Workflow Assurance. Before implementation can create authentic G1 approvals, the organization must still decide:

- 1 who owns the canonical authority roster;
- 2 which real people hold each G1 authority role;
- 3 which qualification evidence is accepted for Cameroon and accounting reviewers;
- 4 which same-person multi-role combinations are permitted or forbidden;
- 5 retention and export rules for approval evidence; and
- 6 whether any G1 decision requires external e-signature evidence rather than internal attestation.

These are governance decisions, not missing code values. They must remain recorded as open rather than guessed.